

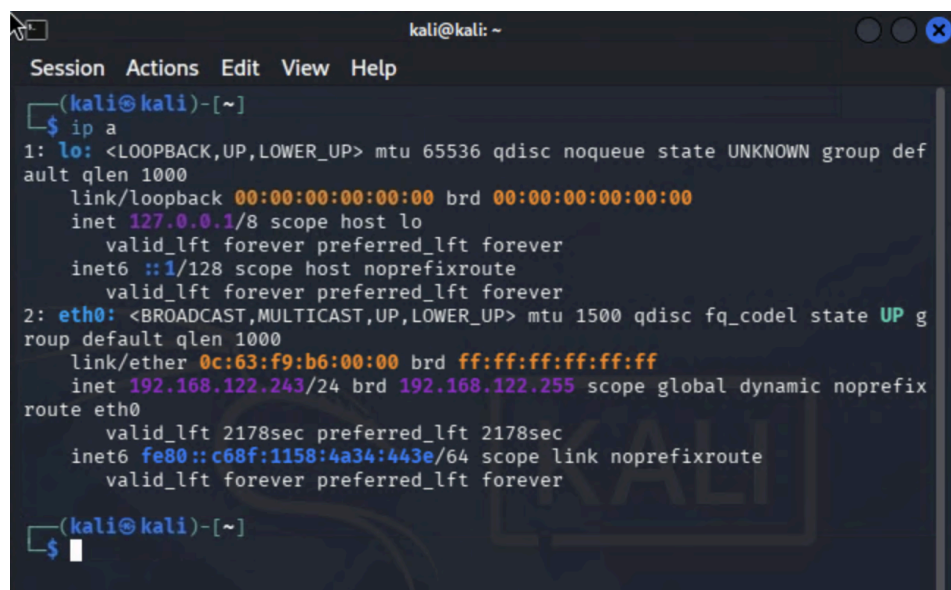
CS07018 – Penetration Testing Engagement in a Controlled Lab

1. Lab Topology, Scope, and Rules of Engagement

1.1 Lab Topology

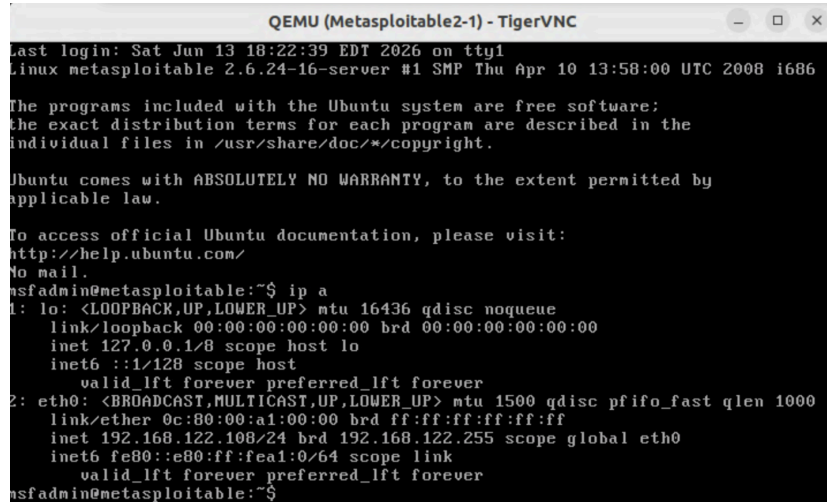
The penetration testing laboratory was implemented using GNS3 and consisted of three virtual machines connected through a virtual switch.

Kali Linux Attacher MV IP: 192.168.122.243



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 0c:63:f9:b6:00:00 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.122.243/24 brd 192.168.122.255 scope global dynamic noprefixroute eth0  
        valid_lft 2178sec preferred_lft 2178sec  
    inet6 fe80::c68f:1158:4a34:443e/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~]  
$
```

Metasploitable2 Target Server VM IP: 192.168.122.108



```
QEMU (Metasploitable2-1) - TigerVNC
Last login: Sat Jun 13 18:22:39 EDT 2026 on tty1
linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 0c:80:00:a1:00:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.122.108/24 brd 192.168.122.255 scope global eth0
        inet6 fe80::e80:ff:fea1:0/64 scope link
            valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

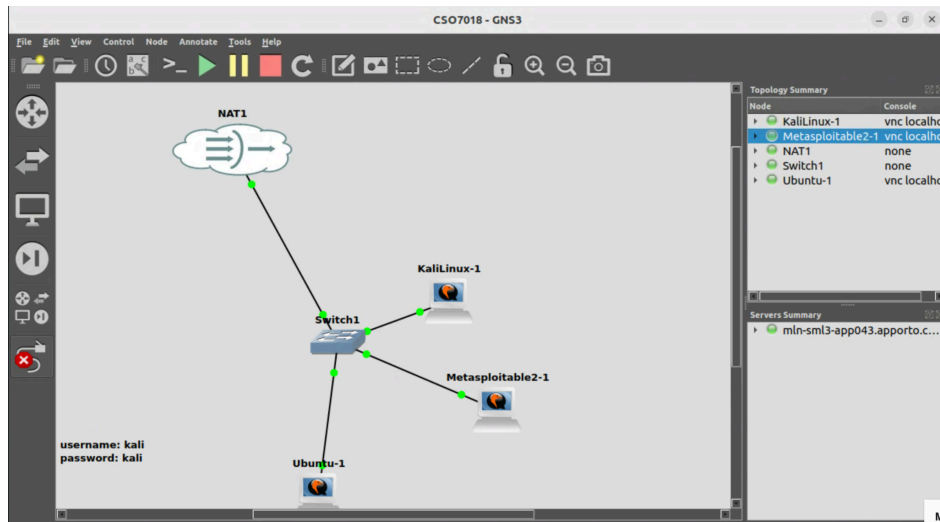
Ubuntu Client VM IP: 192.168.122.71



```
ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996: ~
ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0c:fc:63:1b:00:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.122.71/24 brd 192.168.122.255 scope global dynamic noprefixroute ens4
        valid_lft 2924sec preferred_lft 2924sec
    inet6 fe80::efc:63ff:fe1b:0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996:~$
```

The topology was designed to simulate a realistic internal network environment in which an attacker performs reconnaissance and exploitation activities against a vulnerable server while a legitimate client accesses network services.

Figure 1: GNS3 topology showing Kali Linux, Metasploitable2 and Ubuntu connected through a virtual switch.



1.2 Scope

In-Scope Assets

- Metasploitable2 (192.168.122.108)
- FTP Service
- IRC Service
- Apache Tomcat Service
- SSH Service
- Database Services

Out-of-Scope Assets

- Host operating system
- University infrastructure
- Internet-based systems
- Any device outside the GNS3 environment

1.3 Rules of Engagement

1. All testing was conducted exclusively within the isolated GNS3 laboratory environment.
2. No attacks were directed toward external systems.
3. Only authorised penetration testing tools were used.
4. Evidence was collected throughout the assessment.
5. Activities were performed in accordance with ethical hacking principles.

1.4 Success Criteria

The assessment would be considered successful if:

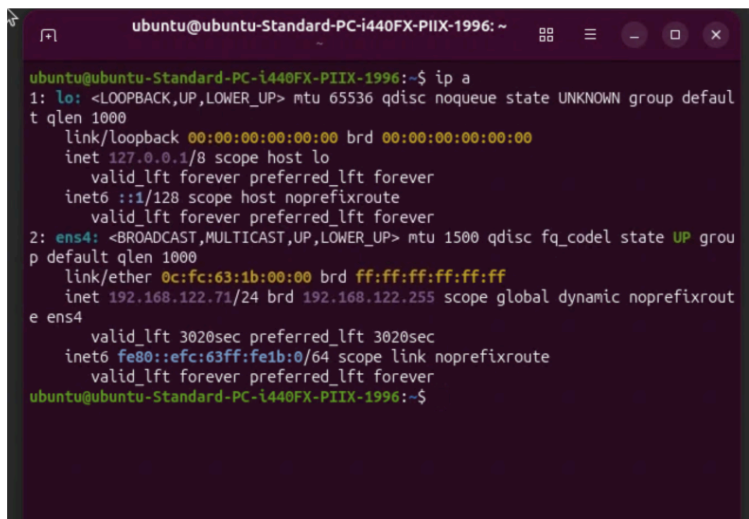
- Network connectivity was verified.
- Active services were identified.
- Vulnerabilities were discovered.
- At least two security findings were demonstrated.
- Appropriate mitigations were proposed.

1.5 Verification of Lab Functionality

Connectivity was verified between laboratory systems.

Ubuntu successfully communicated with Kali Linux using ICMP echo requests, confirming network functionality.

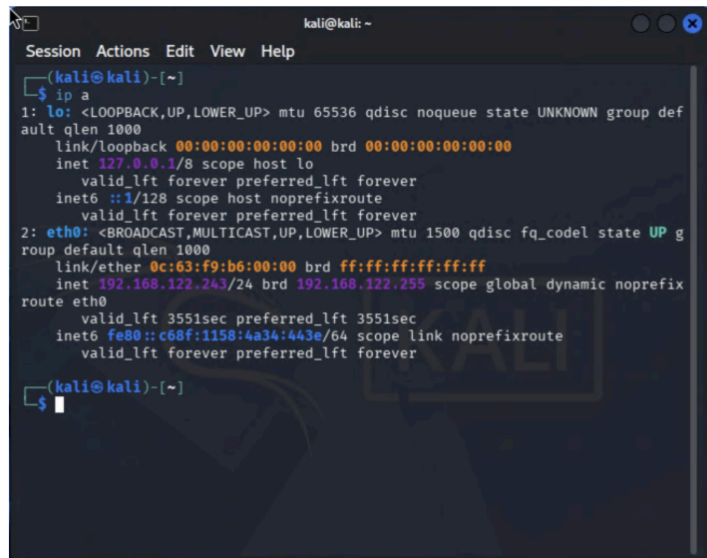
Figure 2: Ubuntu IP configuration

A terminal window titled 'ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996: ~' with standard window controls. The terminal shows the output of the 'ip a' command. It displays details for the loopback interface 'lo' (127.0.0.1) and the ethernet interface 'ens4' (192.168.122.71). The IP address 192.168.122.71 is highlighted in yellow in the original image. The prompt at the bottom is 'ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996:~\$'.

```
ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0c:fc:63:1b:00:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.122.71/24 brd 192.168.122.255 scope global dynamic noprefixroute
        valid_lft 3020sec preferred_lft 3020sec
    inet6 fe80::efc:63ff:fe1b:0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996:~$
```

Figure 2. Ubuntu client network configuration showing IP address 192.168.122.71.

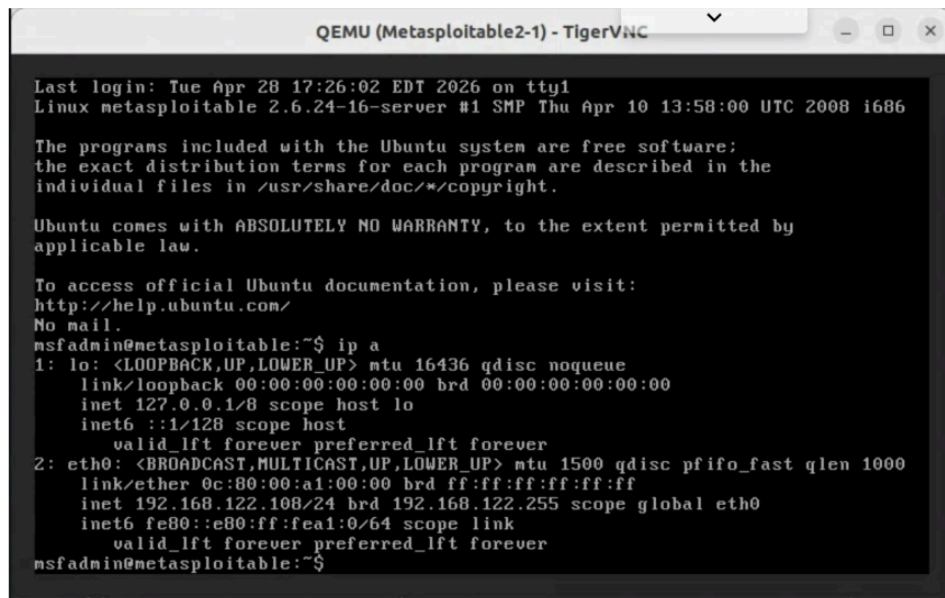
Figure 3: Kali Linux IP configuration

A screenshot of a Kali Linux terminal window. The window title is 'kali@kali: ~'. The terminal shows the output of the 'ip a' command. It displays details for the loopback interface 'lo' (127.0.0.1) and the ethernet interface 'eth0' (192.168.122.243).

```
kali@kali: ~  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def  
ault qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g  
roup default qlen 1000  
    link/ether 0c:63:f9:b6:00:00 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.122.243/24 brd 192.168.122.255 scope global dynamic noprefi  
x route eth0  
        valid_lft 3551sec preferred_lft 3551sec  
    inet6 fe80::c68f:1158:4a34:443e/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
kali@kali: ~  
$
```

Figure 3. Kali Linux attacker machine network configuration showing IP address 192.168.122.243.

Figure 4: Metasploitable2 IP configuration

A screenshot of a Metasploitable2 terminal window. The window title is 'QEMU (Metasploitable2-1) - TigerVNC'. The terminal shows the output of the 'ip a' command. It displays details for the loopback interface 'lo' (127.0.0.1) and the ethernet interface 'eth0' (192.168.122.108).

```
QEMU (Metasploitable2-1) - TigerVNC  
Last login: Tue Apr 28 17:26:02 EDT 2026 on tty1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000  
    link/ether 0c:80:00:a1:00:00 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.122.108/24 brd 192.168.122.255 scope global eth0  
        inet6 fe80::e80:ff:fe01:0/64 scope link  
        valid_lft forever preferred_lft forever  
msfadmin@metasploitable:~$
```

Figure 4. Metasploitable2 target server network configuration showing IP address 192.168.122.108.

Figure 5: Successful ping test between Ubuntu and Kali Linux

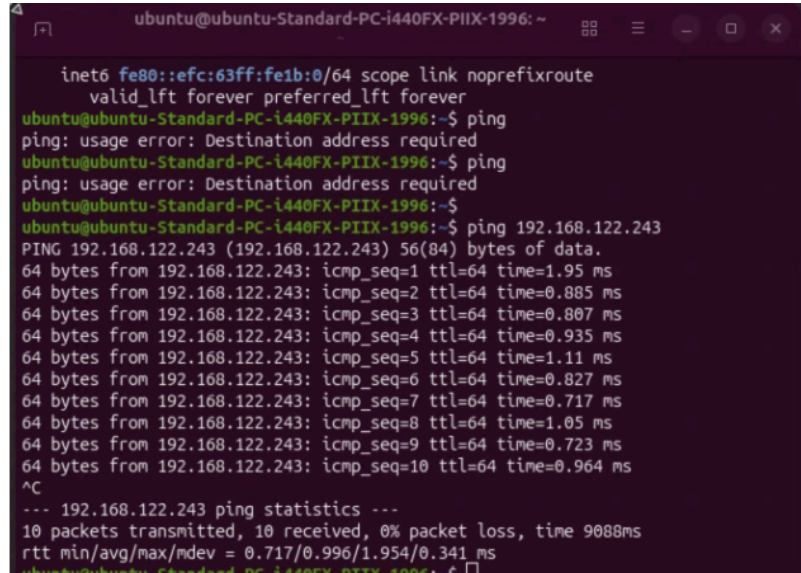
A terminal window with a dark purple background. The prompt is 'ubuntu@ubuntu-Standard-PC-i440FX-PIIX-1996: ~'. The user enters 'ping 192.168.122.243'. The output shows 10 successful ping requests with varying times. At the bottom, it shows 'ping statistics' with 10 packets transmitted, 10 received, 0% packet loss, and a time of 9088ms. The prompt is '\$'.

Figure 5. Successful ICMP connectivity test between Ubuntu (192.168.122.71) and Kali Linux (192.168.122.243), confirming network communication within the laboratory environment.

2. Server/Client Build and Service Configuration Summary

Kali Linux (Attacker)

Kali Linux was configured as the attacker workstation and used throughout the assessment for reconnaissance, vulnerability research, enumeration, and exploitation activities.

Tools used:

- Nmap
- SearchSploit
- Metasploit Framework
- Netcat

Metasploitable2 (Target)

Metasploitable2 was selected as the target system because it contains intentionally vulnerable services commonly used for penetration testing education.

Ubuntu Client

Ubuntu was configured as a legitimate client machine to validate network connectivity and simulate normal network activity.

Identified Services

The following services were identified on Metasploitable2:

Port	Service	Version
1099	Java RMI	GNU Classpath
1524	Bindshell	Metasploitable Root Shell
2049	NFS	RPC Service
2121	FTP	ProFTPD 1.3.1
3306	MySQL	5.0.51a
5432	PostgreSQL	8.3
5900	VNC	Protocol 3.3
6667	IRC	UnrealIRCd
8009	AJP13	Apache JServ
8180	HTTP	Apache Tomcat

3. Penetration Testing Methodology and Execution

The assessment followed a structured penetration testing methodology.

Phase 1 – Reconnaissance

The target environment was identified and connectivity verified.

Phase 2 – Scanning and Enumeration

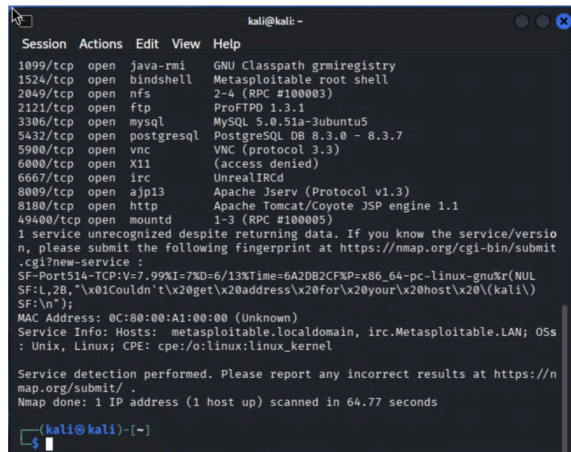
Nmap was used to enumerate active services and determine service versions.

Command used:

```
nmap -sV 192.168.122.108
```

The scan identified multiple exposed services that may present security risks.

Figure 6: Nmap service enumeration results



```
kali@kali: ~  
Session Actions Edit View Help  
1099/tcp open java-rmi GNU Classpath grmiregistry  
1524/tcp open bindshell Metasploitable root shell  
2049/tcp open nfs 2-4 (RPC #100003)  
2121/tcp open ftp ProFTPD 1.3.1  
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5  
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp open vnc VNC (protocol 3.3)  
6000/tcp open X11 (access denied)  
6667/tcp open irc UnrealIRCd  
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)  
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1  
49400/tcp open mountd 1-3 (RPC #100005)  
1 service unrecognized despite returning data. If you know the service/version,  
n, please submit the following fingerprint at https://nmap.org/cgi-bin/submit  
.cgi?new-service :  
SF-Port514-TCP:V=7.99%I=7%D=6/13%Time=6A2DB2CF%P=x86_64-pc-linux-gnu%r(NUL  
SF:L,28,"%01Couldn't%0get%0address%0for%0your%0host%0(kali%  
SF:%n");  
MAC Address: 0C:80:00:A1:00:00 (Unknown)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS:  
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://n  
map.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 64.77 seconds  
  
kali@kali: ~
```

Figure 6. Nmap service enumeration of the Metasploitable2 target (192.168.122.108), identifying multiple exposed services including FTP, MySQL, PostgreSQL, UnrealIRCd, Apache Tomcat, and a root bindshell on TCP port 1524.

Phase 3 – Vulnerability Research

SearchSploit was used to identify publicly known vulnerabilities affecting discovered services.

Command used:

```
searchsploit unrealircd
```

The search revealed several vulnerabilities associated with UnrealIRCd 3.2.8.1 including a backdoor command execution vulnerability.

Figure 7: SearchSploit vulnerability identification


```
(kali㉿kali)-[~]
$ searchsploit unrealircd
```

Exploit Title	Path
UnrealIRCd 3.2.8.1 - Backdoor Command Exec	linux/remote/16922.rb
UnrealIRCd 3.2.8.1 - Local Configuration S	windows/dos/18011.txt
UnrealIRCd 3.2.8.1 - Remote Downloader/Exe	linux/remote/13853.pl
UnrealIRCd 3.x - Remote Denial of Service	windows/dos/27407.pl

```
Shellcodes: No Results

(kali㉿kali)-[~]
$
```

Phase 4 – Exploit Identification

Metasploit Framework was used to identify available exploit modules.

Command used:

search unrealircd

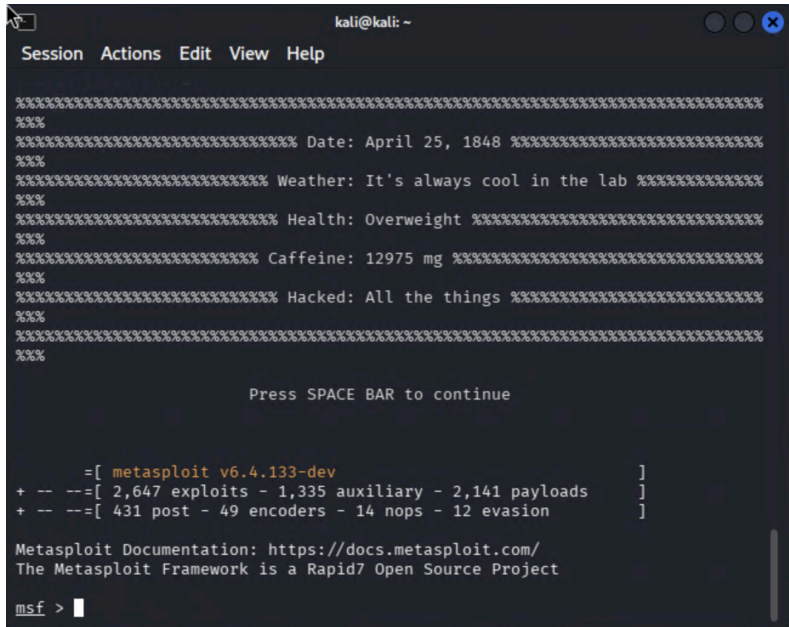
The framework identified:

exploit/unix/irc/unreal_ircd_3281_backdoor

The exploit was ranked as Excellent reliability.

Figure 8:

Metasploit exploit discovery



```
kali@kali: ~
Session Actions Edit View Help

%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Date: April 25, 1848 %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Weather: It's always cool in the lab %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Health: Overweight %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Caffeine: 12975 mg %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%% Hacked: All the things %%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%%

Press SPACE BAR to continue

      =[ metasploit v6.4.133-dev ]
+ -- --=[ 2,647 exploits - 1,335 auxiliary - 2,141 payloads ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > 
```

Figure 8. Metasploit Framework was successfully launched on the Kali Linux attacker machine, providing access to exploit modules, payloads, and auxiliary tools used during the assessment.

4. Attack Demonstrations and Findings

Finding 1 – UnreallRCd Backdoor Vulnerability

Goal and Threat Scenario

The objective was to determine whether the UnreallRCd service identified during enumeration was vulnerable to a known backdoor command execution vulnerability.

Methodology

1. Service discovered using Nmap.
2. Vulnerability identified using SearchSploit.
3. Metasploit exploit module identified.
4. Exploit module loaded and configured.

Evidence

Exploit module:

exploit/unix/irc/unreal_ircd_3281_backdoor

Target configured:

RHOSTS => 192.168.122.108

Figure 9: UnreallRCd exploit module loaded

```
msf5 > search unrealircd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank
--  --
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent
Yes  UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor
msf5 > 
```

Figure 9. Metasploit search results identifying the UnreallRCd 3.2.8.1 Backdoor Command Execution exploit module with an "Excellent" reliability ranking.

Outcome

The target was confirmed to be running a vulnerable version of UnreallRCd with publicly available exploit code.

Impact

A successful attacker could potentially execute commands remotely and compromise the system.

Mitigation

- Upgrade UnreallRCd
- Remove vulnerable versions
- Restrict IRC service access
- Monitor suspicious activity

Finding 2 – Exposed Root Bindshell

Goal and Threat Scenario

The objective was to determine whether the service running on TCP port 1524 permitted unauthorized remote access.

Methodology

Nmap identified a service labelled "Metasploitable Root Shell".

Netcat was used to establish a connection:

```
nc 192.168.122.108 1524
```

Evidence

Commands executed:

```
whoami
```

```
hostname
```

```
pwd
```

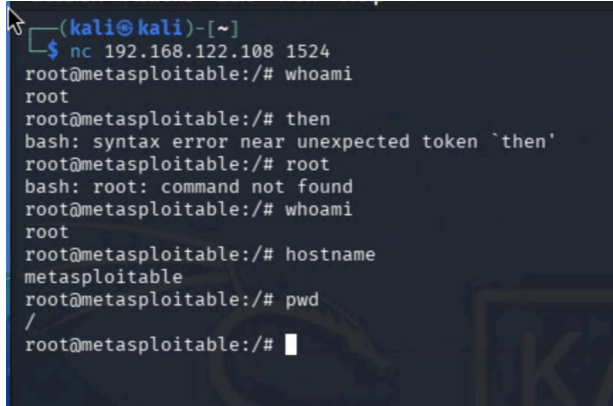
Results:

```
root
```

```
metasploitable
```

```
/
```

Figure 10: Successful root shell access via port 1524

A terminal window showing a netcat listener on Kali Linux. The listener is on IP 192.168.122.108, port 1524. It receives a connection from 192.168.122.108. The user is root@metasploitable. The user runs 'whoami' and gets 'root'. They run 'then' and get a syntax error. They run 'root' and get 'bash: root: command not found'. They run 'whoami' and get 'root'. They run 'hostname' and get 'metasploitable'. They run 'pwd' and get '/'.

```
(kali㉿kali)-[~]  
$ nc 192.168.122.108 1524  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# then  
bash: syntax error near unexpected token `then'  
root@metasploitable:/# root  
bash: root: command not found  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# hostname  
metasploitable  
root@metasploitable:/# pwd  
/  
root@metasploitable:/#
```

Figure 10. Successful connection to the Metasploitable2 target through the exposed bindshell service on TCP port 1524. Post-exploitation validation was performed using the commands `whoami`, `hostname`, and `pwd`, confirming root-level access to the target system and successful remote command execution.

Outcome

Unauthenticated root-level access was obtained.

Impact

An attacker could:

- Execute commands
- Modify files
- Install malicious software
- Create new user accounts
- Fully compromise the system

Mitigation

- Disable the service
- Remove unnecessary services
- Restrict access using firewall controls
- Hardened system configuration

5. Logging, Detection, and Impact Analysis

Figure A

```
root pts/0 :0.0 Sat Jun 13 15:05 - crash (00:50)
reboot system boot 2.6.24-16-server Sat Jun 13 15:05 - 14:24 (23:19)
root pts/0 :0.0 Sat Jun 13 14:15 - crash (00:50)
reboot system boot 2.6.24-16-server Sat Jun 13 14:14 - 14:24 (1+00:09)
root pts/0 :0.0 Sat Jun 13 14:07 - crash (00:07)
reboot system boot 2.6.24-16-server Sat Jun 13 14:06 - 14:24 (1+00:17)
root pts/0 :0.0 Fri Jun 12 09:24 - crash (1+04:41)
reboot system boot 2.6.24-16-server Fri Jun 12 09:24 - 14:24 (2+05:00)
root pts/0 metasploitable:0 Fri Jun 12 04:41 - crash (04:43)
reboot system boot 2.6.24-16-server Fri Jun 12 04:40 - 14:24 (2+09:44)
root pts/0 :0.0 Thu Jun 11 23:00 - crash (05:39)
reboot system boot 2.6.24-16-server Thu Jun 11 23:00 - 14:24 (2+15:24)
root pts/0 :0.0 Thu Jun 11 22:06 - crash (00:53)
reboot system boot 2.6.24-16-server Thu Jun 11 22:06 - 14:24 (2+16:18)
root pts/0 metasploitable:0 Thu Jun 11 21:57 - crash (00:08)
reboot system boot 2.6.24-16-server Thu Jun 11 21:56 - 14:24 (2+16:28)
root pts/0 :0.0 Wed Apr 29 11:04 - crash (43+10:51)
reboot system boot 2.6.24-16-server Wed Apr 29 11:04 - 14:24 (46+03:20)
msfadmin tty1 Tue Apr 28 17:26 - crash (17:38)
msfadmin tty1 Tue Apr 28 17:26 - 17:26 (00:00)
root pts/0 :0.0 Tue Apr 28 17:24 - crash (17:39)
reboot system boot 2.6.24-16-server Tue Apr 28 17:24 - 14:24 (46+21:00)

utmp begins Tue Apr 28 17:24:30 2026
root@metasploitable:/home/msfadmin# _
```

Description:

In order to be able to analyze the attack for suspicious activity, to correlate events that occurred around the time of the attack and to verify whether any unauthorized access to the server was performed the last command was used on the Metasploitable test server in order to gather evidence from the server's historical login and session activity on the server.

Analysis

Evidence of normal user activity as well as administrative activity is collected on the system. Root sessions are typically of particular interest, as one would generally like to keep a close eye on any privileged activity.

Figure B

```
QEMU (Metasploitable2-1) - TigerVNC
reboot system boot 2.6.24-16-server Thu Jun 11 23:00 - 14:24 (2+15:24)
root pts/0 :0.0 Thu Jun 11 22:06 - crash (00:53)
reboot system boot 2.6.24-16-server Thu Jun 11 22:06 - 14:24 (2+16:18)
root pts/0 metasploitable:0 Thu Jun 11 21:57 - crash (00:08)
reboot system boot 2.6.24-16-server Thu Jun 11 21:56 - 14:24 (2+16:28)
root pts/0 :0.0 Wed Apr 29 11:04 - crash (43+10:51)
reboot system boot 2.6.24-16-server Wed Apr 29 11:04 - 14:24 (46+03:20)
msfadmin tty1 Tue Apr 28 17:26 - crash (17:38)
msfadmin tty1 Tue Apr 28 17:26 - 17:26 (00:00)
root pts/0 :0.0 Tue Apr 28 17:24 - crash (17:39)
reboot system boot 2.6.24-16-server Tue Apr 28 17:24 - 14:24 (46+21:00)

utmp begins Tue Apr 28 17:24:30 2026
root@metasploitable:/home/msfadmin# ps aux | head
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.3  2844  1692 ?        Ss   13:54   0:01 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   13:54   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   13:54   0:00 [migration/0]
root         4  0.0  0.0      0     0 ?        S<   13:54   0:00 [ksoftirqd/0]
root         5  0.0  0.0      0     0 ?        S<   13:54   0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   13:54   0:00 [migration/1]
root         7  0.0  0.0      0     0 ?        S<   13:54   0:00 [ksoftirqd/1]
root         8  0.0  0.0      0     0 ?        S<   13:54   0:00 [watchdog/1]
root         9  0.0  0.0      0     0 ?        S<   13:54   0:00 [events/0]
root@metasploitable:/home/msfadmin# _
```

Description:

The `ps aux | head` command within the Kali Linux VM produces a list of the processes currently running on the Metasploitable server (Figure B). Reviewing this output confirms that a typical OS environment is currently established for the Metasploitable2 test lab server. As the attacker gained administrative access to the compromised host, the above list of processes on the compromised host would provide the attacker with information regarding the currently running services and potential targets to establish his or her own persistent attack mechanism on the compromised host.

Analysis

This shows the system was functioning properly as Metasploitable2 during testing. As an attacker, viewing process information on a compromised host would help to identify running services and possible targets to use for creating a persistence module (e.g. root shell, scheduled task, service exploit, etc.).

Indicators of Compromise

The following Indicators of Compromise (IoC's) were identified during the testing of the Metasploitable server.

Nmap scanning activity originating from Kali Linux (192.168.122.243).

Enumeration of exposed services on Metasploitable2 (192.168.122.108).

Discovery of UnrealIRCd on TCP port 6667.

There is an exposed root bindshell on the target host listening on port 1524 (TCP).

Successful unauthenticated remote connection to the bindshell service.

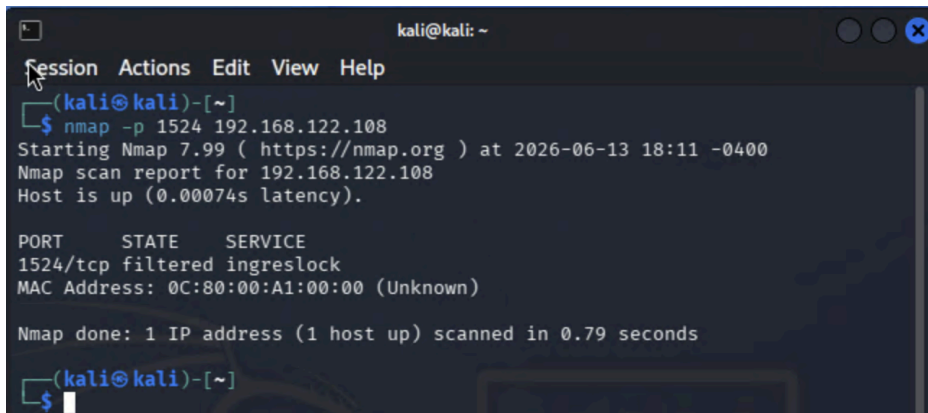
A successful root bindshell connection allows the root bindshell to be verified. Using the `whoami`, `hostname` and `pwd` commands root level commands can be confirmed to have been executed on the target machine.

Firewall rule modification during mitigation testing.

Impact Analysis

If all of this were to happen in a production environment as opposed to a lab, the impact would be to compromise the test machine. In a production environment, the impact could result in a full system compromise and allow an attacker to have complete administrative access to the system. He could then use the system to perform any number of functions including executing commands and sending resulting output to an attacker, modifying files on the system, creating new users with whatever privileges are desired, installing and running malware, etc.

6. Countermeasures, Mitigation, and Re-Test



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -p 1524 192.168.122.108  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 18:11 -0400  
Nmap scan report for 192.168.122.108  
Host is up (0.00074s latency).  
  
PORT      STATE      SERVICE  
1524/tcp  filtered  ingreslock  
MAC Address: 0C:80:00:A1:00:00 (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.79 seconds  
(kali@kali)-[~]  
$
```

Figure 11. Re-test of TCP port 1524 following implementation of a host-based firewall rule. The previously accessible bindshell service is now reported as filtered, preventing unauthorised remote access from the attacker's machine.

Finding 3 – Exposed Root Bindshell

Countermeasure Implemented

To mitigate the risk posed by the exposed root bindshell service on TCP port 1524, a host-based firewall rule was implemented on the target system using iptables.

Command executed:

```
sudo iptables -A INPUT -p tcp --dport 1524 -j DROP
```

This rule blocks incoming connections to the vulnerable service while allowing the remainder of the system to continue operating normally.

Re-Test Procedure

Following implementation of the firewall rule, a re-test was conducted from the Kali Linux attacker machine using Nmap:

```
nmap -p 1524 192.168.122.108
```

Re-Test Results

The service was no longer accessible, and Nmap reported the port state as 1524/tcp filtered

As shown in Figure 11, the mitigation successfully prevented external access to the bindshell service.

Effectiveness Evaluation

This rule will help to stop people from accessing the TCP port 1524 that was opened up by the previous vulnerability for the root shell service. However, there are many other vulnerable services on this host. Further hardening of the host, application of patches where appropriate, and reduction in services that are running on this host are required in order to complete the securing of the host.

Residual Risk

While the specific vulnerability was mitigated, the system remains intentionally insecure and should not be considered secure without additional remediation measures.

7. Reflection on Ethical and Legal Practice

The testing was conducted in an isolated test lab utilizing GNS3. All testing was done within the scope of the lab, and no testing was conducted against outside hosts or systems. The testing followed the principles of ethical hacking, and all testing was conducted within the scope outlined.

The key to securing any network is identifying the vulnerabilities in that network and testing for them in a responsible manner. Using good testing practices in conjunction with good configuration practices is key to securing any network. Businesses should ensure all systems are up to date with the latest software versions and limit the number of services exposed to the internet. Also, monitor critical systems for any issues that could affect business operations.